16.3.2 Building and maintaining ACME’s trust store

Once ACME determines that an issuer is trustworthy for a specific set of credential types, the identity team records that decision in ACME’s trust store. The *trust store* is a registry of issuers that ACME depends on, along with the credential types it accepts for each vendor. This is not simply a list of public keys; it is a governance artifact that captures ACME’s decision that an issuer is authoritative for certain credential types and outlines the scope of that trust.

For example, after reviewing NISA’s governance framework and the accreditation credential issued to AuditsRUs, Tim added AuditsRUs to the trust store as an issuer ACME recognizes for employment and role credential types. He also added NISA as a trusted issuer for the CISA-R certification credential type. These trust decisions are scoped. ACME does not trust AuditsRUs to issue certification credentials, nor does it trust NISA for employment credentials. By scoping trust this way, ACME protects the security of its processes and ensures that each external organization can only assert the credential types within its recognized authority. This prevents vendors from exceeding their intended role and keeps ACME’s authorization decisions grounded in well-defined sources of authority.

Maintaining the trust store is an ongoing responsibility, but it does not require ACME to monitor the ongoing performance or compliance of each credential issuer. ACME trusts NISA because Tim conducted a thorough evaluation of NISA’s governance framework and concluded that NISA’s accreditation process is reliable. That evaluation gives ACME significant leverage: any firm or individual auditor accredited by NISA can now be trusted without repeating the analysis. ACME’s role is simply to ensure that the accreditation credentials on which its trust decisions rely remain valid and have not been revoked. If NISA were to revoke AuditsRUs’s accreditation, ACME would update its trust store accordingly. These updates might happen automatically either through periodic checks that ACME’s infrastructure makes or via a subscription to NISA’s trust registry. If this were to happen, future credentials from AuditsRUs would no longer satisfy policies requiring work by accredited auditors. This change would also impact individuals. If Brian, another auditor at AuditsRUs, tried to access